

Information Security Risk Assessment

Comprehensive Risk Identification and Evaluation Framework

Assessment Date: _____

Assessor: _____

Organization: _____

Review Date: _____

Contents

1	Introduction	3
1.1	Purpose	3
1.2	Scope	3
1.3	Methodology	3
1.4	Definitions	4
2	Asset Identification	5
2.1	Asset Inventory	5
2.2	Asset Classification	5
2.3	Asset Valuation	5
3	Threat Identification	6
3.1	Threat Sources	6
3.2	Common Threats by Domain	6
3.2.1	User Domain Threats	6
3.2.2	Workstation Domain Threats	6
3.2.3	Network Domain Threats	6
3.2.4	Application Domain Threats	7
4	Vulnerability Identification	8
4.1	Vulnerability Assessment Methodology	8
4.2	Common Vulnerabilities	8
4.3	Vulnerability Details	8
5	Risk Analysis	9
5.1	Risk Calculation Methodology	9
5.1.1	Quantitative Risk Analysis	9
5.1.2	Qualitative Risk Analysis	9
5.2	Risk Register	9
5.3	Risk Scoring Matrix	10
6	Risk Treatment	11
6.1	Treatment Options	11
6.2	Risk Treatment Plan	11
6.3	Control Recommendations	11
6.3.1	Administrative Controls	11
6.3.2	Technical Controls	12
6.3.3	Physical Controls	12
7	Residual Risk Assessment	13
7.1	Residual Risk Calculation	13
7.2	Residual Risk Register	13

8	Recommendations and Conclusion	14
8.1	Executive Recommendations	14
8.2	Conclusion	14

Executive Summary

Executive Summary

Provide a brief overview of the risk assessment, including:

- Purpose and scope of the assessment
- Key findings and critical risks
- Summary of risk treatment recommendations
- Overall risk posture assessment

1 Introduction

1.1 Purpose

This risk assessment document provides a structured methodology for identifying, analyzing, and evaluating risks to [Organization Name]'s information assets. The assessment follows industry best practices as defined in NIST SP 800-30, ISO/IEC 27005, and other recognized frameworks.

1.2 Scope

The scope of this risk assessment includes:

Domain	Included Assets
User Domain	All employees, contractors, and third-party users
Workstation Domain	Desktops, laptops, and mobile devices
LAN Domain	Network switches, routers, and internal servers
LAN-to-WAN Domain	Firewalls, VPNs, and DMZ infrastructure
WAN Domain	Internet connections and external communications
Remote Access Domain	VPN, remote desktop, and mobile access
System/Application Domain	Servers, databases, and enterprise applications

1.3 Methodology

This risk assessment follows a structured approach:

1. **Asset Identification:** Cataloging all information assets
2. **Threat Identification:** Identifying potential threats
3. **Vulnerability Identification:** Identifying weaknesses in controls
4. **Risk Analysis:** Evaluating the likelihood and impact of risks
5. **Risk Evaluation:** Prioritizing risks for treatment
6. **Risk Treatment:** Recommending controls and mitigation strategies

1.4 Definitions

Term	Definition
Asset	Any data, device, or component that supports information-related activities
Threat	A potential cause of harm to an asset
Vulnerability	A weakness that could be exploited by a threat
Risk	The potential for loss or damage: $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
Inherent Risk	Risk before controls are applied
Residual Risk	Risk after controls are applied

2 Asset Identification

2.1 Asset Inventory

Asset	Asset Owner	Description
Customer Database	CTO	All customer records, including PII
Financial Systems	CFO	General ledger and financial reporting
HR Database	HR Director	Employee records and compensation data
Email System	CTO	Internal and external email communications
Web Servers	CTO	Public-facing websites
Network Infrastructure	CTO	Switches, routers, firewalls
Desktop Computers	CTO	Employee workstations
Mobile Devices	CTO	Laptops, tablets, smartphones
Backup Systems	CTO	Data backups and recovery media

2.2 Asset Classification

Asset	Classification	Protection Level
Customer Database	Restricted	Highest
Financial Systems	Confidential	High
HR Database	Restricted	Highest
Email System	Internal Use Only	Moderate
Web Servers	Public/Internal	Moderate
Network Infrastructure	Internal Use Only	High
Desktop Computers	Internal Use Only	Moderate
Mobile Devices	Internal Use Only	Moderate
Backup Systems	Confidential	High

2.3 Asset Valuation

Asset	Value Category	Estimated Value
Customer Database	Critical	\$10,000,000+
Financial Systems	Critical	\$5,000,000+
HR Database	Critical	\$3,000,000+
Email System	High	\$500,000+
Web Servers	High	\$250,000+
Network Infrastructure	High	\$1,000,000+
Desktop Computers	Moderate	\$250,000+
Mobile Devices	Moderate	\$100,000+
Backup Systems	High	\$500,000+

3 Threat Identification

3.1 Threat Sources

Threat Source	Category	Examples
Cybercriminals	Human	Hackers, criminal organizations
Nation-States	Human	Government-sponsored actors
Insiders	Human	Disgruntled employees, careless employees
Hactivists	Human	Ideologically motivated attackers
Malware	Technical	Viruses, worms, ransomware
Natural Disasters	Environmental	Fire, flood, earthquake
Power Outages	Environmental	Equipment failure, grid failure
Third-Party Vendors	Human	Supplier breaches, supply chain attacks

3.2 Common Threats by Domain

3.2.1 User Domain Threats

- Social engineering and phishing attacks
- Weak password selection
- Accidental data disclosure
- Insider threats (malicious and unintentional)
- Policy violations

3.2.2 Workstation Domain Threats

- Malware infection
- Unauthorized software installation
- Physical theft of devices
- Unpatched vulnerabilities
- Compromised credentials

3.2.3 Network Domain Threats

- Man-in-the-middle attacks
- Denial-of-service (DoS) attacks
- Network sniffing
- Unauthorized access
- Routing attacks

3.2.4 Application Domain Threats

- SQL injection
- Cross-site scripting (XSS)
- Session hijacking
- Buffer overflow attacks
- Authentication bypass

4 Vulnerability Identification

4.1 Vulnerability Assessment Methodology

The vulnerability identification process includes:

1. Automated vulnerability scanning (e.g., Nessus, OpenVAS)
2. Manual penetration testing
3. Configuration review against security benchmarks (CIS, NIST)
4. Security architecture review
5. Policy and procedure review

4.2 Common Vulnerabilities

Vulnerability	Domain	Potential Impact
Unpatched Software	System/Application	System compromise, data breach
Weak Passwords	User/Workstation	Account compromise
Missing MFA	All	Unauthorized access
Open Ports	Network	Attack surface exposure
Lack of Encryption	Data/Network	Data interception
Misconfigured Firewall	LAN-to-WAN	Network exposure
Insufficient Logging	System/Application	Undetected breaches
Unrestricted USB Access	Workstation	Data exfiltration
Third-Party Risks	All	Supply chain compromise

4.3 Vulnerability Details

For each vulnerability, provide the following information:

Vulnerability Detail Template

- **Vulnerability ID:** VULN-001
- **Description:** _____
- **Affected Assets:** _____
- **CVE ID:** _____ (if applicable)
- **CVSS Score:** _____ (if applicable)
- **Existing Controls:** _____
- **Recommended Controls:** _____
- **Responsible Party:** _____

5 Risk Analysis

5.1 Risk Calculation Methodology

5.1.1 Quantitative Risk Analysis

Quantitative Risk Formulas

$$SLE(Single Loss Expectancy) = Asset Value (AV) \times Exposure Factor (EF)$$
$$ALE(Annualized Loss Expectancy) = SLE \times Annualized Rate of Occurrence (ARO)$$

(1)

(2)

5.1.2 Qualitative Risk Analysis

Qualitative Risk Matrix

Likelihood				
	Rare	Unlikely	Possible	Likely
Catastrophic	High	High	Critical	Critical
Major	Medium	High	High	Critical
Moderate	Medium	Medium	High	High
Minor	Low	Low	Medium	Medium

5.2 Risk Register

ID	Asset	Threat	Vulnerability	Likelihood	Impact	Risk Level	Priority
R-001	Customer DB	Data Breach	Unpatched Web Server	3	5	15	High
R-002	Customer DB	Insider Threat	Excessive Access	2	5	10	Medium
R-003	Financial Systems	Ransomware	Unpatched OS	3	4	12	High
R-004	Email System	Phishing	Lack of Training	4	3	12	High
R-005	Network	DDoS	Insufficient Capacity	3	3	9	Medium
R-006	Customer DB	Data Loss	Backup Failure	2	5	10	Medium
R-007	Web Servers	Defacement	Weak Passwords	3	2	6	Low

R-008	Mobile Devices	Theft	Lack of Encryption	3	4	12	High
R-009	Network	MITM	Unencrypted Traffic	2	4	8	Medium
R-010	HR Database	Data Breach	Third-Party Risk	3	5	15	High
R-011	Backup Systems	Data Loss	Inadequate Testing	3	4	12	High
R-012	All Assets	Power Outage	No UPS/Generator	2	4	8	Medium

Table 8: Comprehensive Risk Register

5.3 Risk Scoring Matrix

Risk Score Explanation		
Risk Level	Score Range	Action Required
Critical	15-25	Immediate mitigation required
High	10-14	Mitigation within 30 days
Medium	5-9	Mitigation within 90 days
Low	1-4	Accept or monitor

6 Risk Treatment

6.1 Treatment Options

Option	Description	Example
Accept	Accept the risk without action	Minor risks with low impact
Mitigate	Implement controls to reduce risk	Install firewall, implement MFA
Transfer	Shift risk to a third party	Cyber insurance, outsourcing
Avoid	Eliminate the risk entirely	Discontinue a risky activity

6.2 Risk Treatment Plan

ID	Risk	Treatment Option	Control	Responsible	Target Date
R-001	Unpatched Web Server	Mitigate	Patch Management Process	CTO	30 days
R-002	Excessive Access	Mitigate	Access Review	Security	60 days
R-003	Unpatched OS	Mitigate	Automated Patching	IT	30 days
R-004	Lack of Training	Mitigate	Security Awareness Program	CISO	90 days
R-005	DDoS	Transfer	DDoS Protection Service	CTO	60 days
R-006	Backup Failure	Mitigate	Backup Testing	IT	30 days
R-007	Weak Passwords	Mitigate	Password Policy Enforcement	Security	30 days
R-008	Lack of Encryption	Mitigate	Full Disk Encryption	IT	45 days
R-009	MITM	Mitigate	TLS/SSL Implementation	Security	60 days
R-010	Third-Party Risk	Mitigate	Vendor Risk Assessment	Security	90 days
R-011	Inadequate Testing	Mitigate	DRP Testing	IT	45 days
R-012	Power Outage	Accept	Monitor	Facilities	N/A

Table 10: Risk Treatment Plan

6.3 Control Recommendations

6.3.1 Administrative Controls

- Develop and enforce security policies
- Conduct regular security awareness training
- Implement background checks for new hires

- Establish incident response procedures

6.3.2 Technical Controls

- Implement multi-factor authentication
- Deploy next-generation firewalls
- Install intrusion detection/prevention systems
- Implement endpoint detection and response (EDR)

6.3.3 Physical Controls

- Implement access control systems
- Install surveillance cameras
- Establish security guard procedures
- Implement environmental controls (fire suppression, climate control)

7 Residual Risk Assessment

7.1 Residual Risk Calculation

$$ResidualRisk = InherentRisk - ControlEffectiveness \quad (3)$$

7.2 Residual Risk Register

ID	Risk	Control	Inherent Risk	Residual Risk	Status
R-001	Unpatched Web Server	Patch Management	15	5	Acceptable
R-002	Excessive Access	Access Review	10	3	Acceptable
R-003	Unpatched OS	Automated Patching	12	4	Acceptable
R-004	Lack of Training	Awareness Program	12	5	Acceptable
R-005	DDoS	Protection Service	9	2	Acceptable
R-006	Backup Failure	Backup Testing	10	3	Acceptable
R-007	Weak Passwords	Policy Enforcement	6	2	Acceptable
R-008	Lack of Encryption	Full Disk Encryption	12	3	Acceptable
R-009	MITM	TLS/SSL Implementation	8	2	Acceptable
R-010	Third-Party Risk	Vendor Assessment	15	6	Acceptable
R-011	Inadequate Testing	DRP Testing	12	3	Acceptable
R-012	Power Outage	None (Accepted)	8	8	Accepted

Table 11: Residual Risk Register

8 Recommendations and Conclusion

8.1 Executive Recommendations

Top 5 Recommendations

1. **Implement Patch Management Program:** Establish a formal process for identifying, testing, and applying security patches
2. **Deploy Multi-Factor Authentication:** Require MFA for all privileged and remote access
3. **Conduct Security Awareness Training:** Implement ongoing training for all employees
4. **Strengthen Access Controls:** Implement least privilege and need-to-know principles
5. **Establish Incident Response Capability:** Develop and test incident response procedures

8.2 Conclusion

The risk assessment has identified [Number] risks across all seven domains of the IT infrastructure. Of these, [Number] are classified as critical or high risk and require immediate attention. The recommended controls are estimated to reduce the overall risk exposure to an acceptable level. This risk assessment should be reviewed and updated:

- Annually (minimum)
- When significant changes occur in the threat landscape
- When new systems or applications are deployed
- Following significant security incidents

Appendices

Appendix A: Detailed Risk Matrix

This appendix contains detailed risk analysis for each asset.

Appendix B: Control Mapping

This appendix maps controls to NIST SP 800-53 and ISO/IEC 27001.

Appendix C: Vulnerability Scan Results

This appendix contains the results of vulnerability scans.

Appendix D: Glossary of Terms

This appendix contains detailed definitions of all terms used.